REPORT DI VULNERABILITY ASSESSMENT

Enumerazione del banner del servizio Telnet

Modulo Metasploit `auxiliary/scanner/telnet/telnet_version` – target Metasploitable2

Controllo documento	
Titolo	Telnet Service Banner Detection – Report Epicode W16D2
Autore	Donato Squicciarino
Corso	Cybersecurity Part Time – Epicode
Esercizio	Esercizio di fine modulo W16D2
Data	2 novembre 2026
Versione	1.0
Classificazione	Uso didattico – ambiente di laboratorio

1. Sintesi esecutiva

L'attività ha avuto lo scopo di verificare, con un approccio di vulnerability assessment, quali informazioni espone il servizio Telnet (23/TCP) della macchina Metasploitable2 `192.168.1.40`, raggiunta dalla macchina Kali Linux `192.168.1.25`. È stato usato il modulo ausiliario di Metasploit `telnet_version`, uno scanner di banner grabbing e non un exploit, seguito da una verifica manuale con il client `telnet`.

Risultato principale: il servizio Telnet è attivo e raggiungibile, e il banner di benvenuto, visibile a chiunque si connetta prima di qualsiasi autenticazione, riporta le credenziali di default `msfadmin`/`msfadmin`. Poiché Telnet non cifra il traffico, l'esposizione riguarda sia il banner sia ogni futura sessione di login. È stato rilevato **un solo finding, di severità Alta (CVSS v3.1 7.5)**.

Severità	N.	Finding
Critica	0	–
Alta	1	TEL-001 – Servizio Telnet in chiaro con credenziali di default esposte nel banner
Media	0	–
Bassa	0	–

Azione prioritaria: disabilitare Telnet in favore di SSH, rimuovere le credenziali dal banner e sostituire le credenziali di default (vedi sezione 5).

2. Ambito e metodologia

2.1 Ambito

Elemento	Dettaglio
Target	Metasploitable2 – `192.168.1.40`
Sistema di test	Kali Linux – `192.168.1.25`
Servizio in esame	Telnet – 23/TCP
Strumenti	Metasploit Framework (`msfconsole`, v6.5.5-dev), client `telnet`
Ambiente	Laboratorio didattico, rete privata isolata
Tipo di attività	Vulnerability assessment (ricognizione e verifica); nessuno sfruttamento

2.2 Metodologia

L'attività ha seguito quattro fasi, dalla ricognizione alla verifica manuale:

- **Preparazione**: avvio di `msfconsole` e individuazione del modulo auxiliary adatto.
- **Configurazione**: analisi dei parametri e impostazione del target (`RHOSTS`).
- **Scansione**: esecuzione del modulo per rilevare il servizio e il suo banner.
- **Verifica manuale**: connessione diretta alla porta 23 per confermare il risultato e osservare l'informazione realmente esposta.

2.3 Limiti dell'attività

- È stato analizzato un solo host e un solo servizio; non è stata fatta una scansione completa delle porte.
- Non è stato tentato alcun login: la validità delle credenziali e il livello di privilegi dell'account `msfadmin` non sono stati verificati.
- La severità CVSS è una stima basata sull'esposizione osservata, non su un'analisi completa dell'ambiente.

3. Attività svolte ed evidenze tecniche

3.1 Avvio di Metasploit

Comando

```
msfconsole
```

Obiettivo: avviare la console interattiva di Metasploit Framework, da cui cercare e lanciare il modulo di scansione.

Esito: console avviata correttamente (v6.5.5-dev, 2.684 exploit e 1.352 moduli auxiliary disponibili, Figura 1).

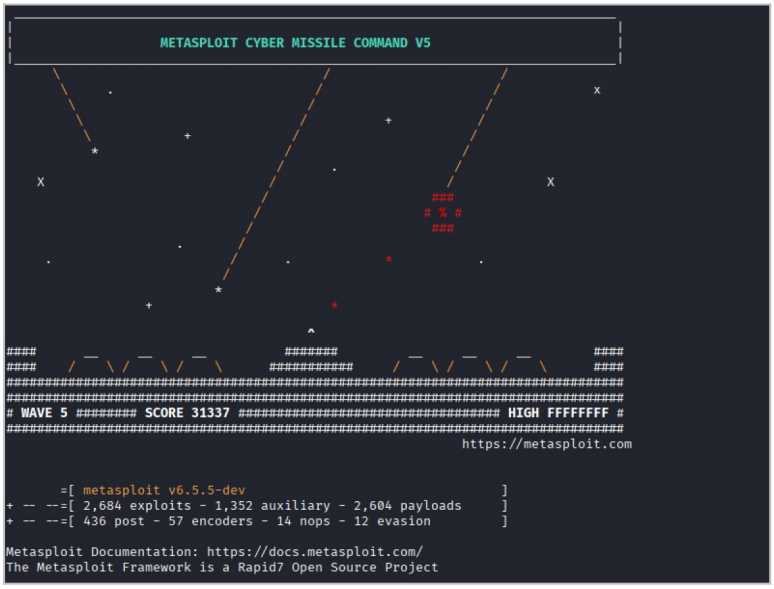


Figura 1 *– Avvio di msfconsole (Metasploit v6.5.5-dev).*

3.2 Ricerca e configurazione del modulo

Comandi

```
search telnet_version
use 1
show options
```

Obiettivo: individuare i moduli di banner grabbing per Telnet e analizzarne i parametri. La ricerca ha restituito due moduli: `lantronix_telnet_version`, specifico per dispositivi Lantronix, e `scanner/telnet/telnet_version` ("Telnet Service Banner Detection"), generico. È stato selezionato quest'ultimo con `use 1`, perché il target è un sistema Linux e non un dispositivo Lantronix.

Esito (Figura 2): l'unico parametro obbligatorio senza valore è `RHOSTS`. Gli altri hanno già un default: `RPORT` 23, `THREADS` 1, `TIMEOUT` 30 s. `USERNAME` e `PASSWORD` sono opzionali e consentirebbero un'autenticazione automatica, non usata in questa attività.

```
msf > search telnet_version

Matching Modules
================

   #  Full Name                                          Disclosure Date  Rank    Check  Name
   -  ---------                                          ---------------  ----    -----  ----
   0  auxiliary/scanner/telnet/lantronix_telnet_version  .                normal  No     Lantronix Telnet Service Banner Detection
   1  auxiliary/scanner/telnet/telnet_version            .                normal  No     Telnet Service Banner Detection


Interact with a module by name or index. For example info 1, use 1 or use auxiliary/scanner/telnet/telnet_version

msf > use 1
msf auxiliary(scanner/telnet/telnet_version) > show options

Module options (auxiliary/scanner/telnet/telnet_version):

   Name      Current Setting  Required  Description
   ----      ---------------  --------  -----------
   PASSWORD                   no        The password for the specified username
   RHOSTS                     yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
   RPORT     23               yes       The target port (TCP)
   THREADS   1                yes       The number of concurrent threads (max one per host)
   TIMEOUT   30               yes       Timeout for the Telnet probe
   USERNAME                   no        The username to authenticate as
```

Figura 2 *– Ricerca del modulo telnet_version e opzioni disponibili.*

3.3 Scansione del banner

Comandi

```
set rhost 192.168.1.40
exploit
```

Obiettivo: impostare il target e avviare la scansione. Per un modulo auxiliary `exploit` è un alias di `run`.

Esito (Figura 3): il modulo riporta `192.168.1.40:23 - TELNET`, confermando che il servizio è attivo e raggiungibile, e termina con "Scanned 1 of 1 hosts (100% complete)".

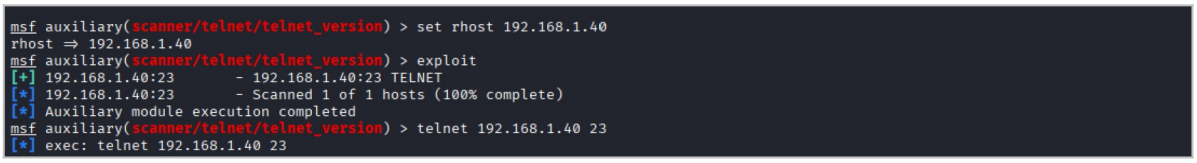


***Figura 3** – Esecuzione del modulo sul target 192.168.1.40.*

3.4 Verifica manuale del banner

Comando

```
telnet 192.168.1.40 23
```

Obiettivo: osservare direttamente, senza l'intermediazione di Metasploit, ciò che il servizio mostra a un client.

Esito (Figura 4): la connessione viene stabilita e compare il banner ASCII art di Metasploitable con questi messaggi:

- "Warning: Never expose this VM to an untrusted network!"
- "Login with msfadmin/msfadmin to get started"

Le credenziali di default sono quindi leggibili in chiaro, senza autenticazione, da chiunque raggiunga la porta 23. La sessione è stata poi chiusa dal server ("Connection closed by foreign host") senza che venisse eseguito alcun login.



***Figura 4** – Connessione manuale via Telnet: il banner riporta le credenziali di default.*

4. Finding

TEL-001 – Telnet in chiaro con credenziali di default nel banner

Scheda	
ID	TEL-001
Asset	`192.168.1.40` – Telnet 23/TCP
Severità	**Alta**
CVSS v3.1	7.5 – `AV:N/AC:L/PR:N/UI:N/C:H/I:N/A:N`
Classificazione	CWE-319 (trasmissione di dati sensibili in chiaro); CWE-1392 (uso di credenziali di default)
Stato	Confermato (verifica manuale, Figure 3 e 4)

Descrizione

Il servizio Telnet è raggiungibile in rete e il suo banner di benvenuto pubblica le credenziali di default del sistema. Telnet è un protocollo legacy che non cifra il canale: username, password e comandi viaggiano in chiaro.

Impatto

- **Riservatezza**: le credenziali sono ottenibili da chiunque raggiunga la porta, senza alcuna autenticazione.
- **Intercettazione**: un attaccante in posizione di sniffing sulla rete può leggere le sessioni Telnet, incluse le credenziali reali.
- **Accesso non autorizzato**: se le credenziali pubblicate sono valide, consentono un accesso immediato al sistema. Questo scenario non è stato verificato.

Scenario di attacco

Un attaccante con accesso alla rete (1) individua la porta 23 aperta, (2) legge il banner e (3) prova le credenziali mostrate, ottenendo potenzialmente una shell sul sistema. In alternativa, intercetta il traffico Telnet di altri utenti.

Riferimenti

MITRE ATT&CK: T1046 (Network Service Discovery), T1040 (Network Sniffing), T1078.001 (Valid Accounts: Default Accounts).

5. Remediation

#	Azione	Dettaglio	Priorità
1	Disabilitare Telnet	Sostituirlo con SSH, che cifra il canale e offre un'autenticazione robusta.	**Alta**
2	Rimuovere le credenziali dal banner	Eliminare ogni credenziale dai messaggi di benvenuto (ad esempio `/etc/issue`, `/etc/issue.net`, `/etc/motd`).	**Alta**
3	Sostituire le credenziali di default	Usare credenziali uniche e complesse per ogni account, con rotazione periodica.	**Alta**
4	Limitare l'accesso	Se Telnet deve restare attivo per motivi legacy o didattici, consentirlo solo da reti fidate con firewall o VPN.	**Media**
5	Verificare la correzione	Ripetere la scansione della porta 23 e l'esecuzione di `telnet_version` per confermare che il servizio non risponda più.	**Media**

6. Conclusioni

L'attività ha mostrato che non tutte le esposizioni critiche derivano da falle software complesse. Un singolo modulo di ricognizione, combinato con una verifica manuale, ha dimostrato che il servizio Telnet pubblica le credenziali di default del sistema in un banner leggibile da chiunque raggiunga la porta 23.

I servizi legacy non cifrati vanno quindi inclusi sempre nella fase di ricognizione di un VA/PT: sono spesso sottovalutati rispetto alle vulnerabilità più "tecniche", ma possono da soli compromettere la sicurezza di un sistema. La correzione è semplice e a basso costo: sostituire Telnet con SSH e rimuovere le credenziali dai banner.

Appendice A – Riepilogo comandi

Comando	Funzione
`msfconsole`	Avvia la console di Metasploit
`search telnet_version`	Cerca i moduli per il banner Telnet
`use 1`	Seleziona `auxiliary/scanner/telnet/telnet_version`
`show options`	Mostra i parametri del modulo
`set rhost 192.168.1.40`	Imposta il target
`exploit`	Esegue il modulo (alias di `run`)
`telnet 192.168.1.40 23`	Connessione manuale al servizio

Appendice B – Riferimenti

- CWE-319: Cleartext Transmission of Sensitive Information – cwe.mitre.org
- CWE-1392: Use of Default Credentials – cwe.mitre.org
- MITRE ATT&CK: T1046, T1040, T1078.001 – attack.mitre.org
- FIRST – CVSS v3.1 Specification – first.org/cvss
- Documentazione Metasploit – docs.metasploit.com